گزارش تضمین کیفیت و امنیت نرم‌افزار

گزارش جامع آزمون‌های کد، کیفیت ساخت و ارزیابی امنیت

FastLove | نسخه دمو 1.0.5 | Android + Admin Web + Demo API

Generated: 2026-11-02 08:10 UTC | Pipeline: PARTIAL - SOME STAGES NOT RUN OR FAILED

خلاصه مدیریتی

در اجرای فعلی، 14 کنترل امنیتی ثابت و 8 تست پنل وب/API با نتیجه Pass ثبت شده‌اند؛ ساخت پنل وب PASS است و اعتبارسنجی XML اندروید PASS گزارش شده است. مراحل اجرا نشده در این گزارش به‌صراحت NOT RUN باقی مانده‌اند. به علت نبود بک‌اند واقعی و چند مانع مهم امنیتی، نسخه دمو مجوز انتشار عمومی یا Production ندارد.

تصمیم انتشار: NO-GO برای Production

این سورس یک دمو است؛ بک‌اند واقعی ندارد و کنترل‌های مسدودکننده انتشار در بخش یافته‌ها ثبت شده‌اند.

8 files	PASS	8/8	14/14
Android XML validation	Admin Web build	Admin Web/API tests	Static security controls

مشخصات گزارش و اجرای پایپ‌لاین

مشخصه	مقدار
زمان تولید	UTC 08:10 2026-11-02
منبع اجرا	Local workspace
Branch / Ref	`local`
Commit	`not availabl`
Run	Local verification
نسخه محصول	FastLove Demo 1.0.5

مرحله / کنترل	نتیجه
Static security configuration checks	PASS
Admin Web/API automated tests	PASS
Admin Web build	PASS
Android XML validation	PASS
Android JVM unit tests	NOT RUN
Android Lint	NOT RUN
Android Release build (R8)	NOT RUN
Android JaCoCo coverage	NOT RUN
Android instrumented UI tests	NOT RUN
Gitleaks secret scan	NOT RUN
CodeQL SAST (JavaScript/Kotlin)	NOT RUN
OSV dependency scan	NOT RUN

نتایج کنترل‌های امنیتی ایستا

تعداد کنترل‌های موجود در گزارش: 14 | موفق: 14 | ناموفق: 0. جزئیات کنترل‌ها در جدول زیر آمده است.

شناسه	کنترل امنیتی	وضعیت	توضیح
AND-001	Android cleartext networking disabled	PASS	.Manifest and Network Security Config explicitly prohibit cleartext HTTP
AND-002	Android system trust anchors only	PASS	.Custom user-added CA certificates are not trusted by the app network policy
AND-003	Android backup disabled and data domains excluded	PASS	Manifest references backup policies and backup/device-transfer exclusions cover .app-local data and SharedPreferences
AND-004	Android target API 36	PASS	.Required target API for new Google Play submissions as of 31 Aug 2026
AND-005	Android Gradle Plugin supports API 36	PASS	.AGP must be at least 8.9.1 to compile/target API 36
AND-006	Android release minification and resource shrinking	PASS	.R8 and resource shrinking are enabled for release builds
AND-007	Android Gson model keep rules exist	PASS	.Names and fields for local Gson-reflection models are retained
AND-008	FileProvider is not exported and paths are narrow	PASS	.The provider only exposes camera capture, app pictures and support attachments
WEB-001	-Demo server defaults to loopback and opt in remote binding	PASS	.Network-visible demo mode requires an explicit unsafe override
WEB-002	Production execution is blocked for JSON demo API	PASS	.The demo JSON API refuses production mode

شناسه	کنترل امنیتی	وضعیت	توضیح
WEB-003	HTTP security headers configured	PASS	.CSP, anti-framing, MIME sniffing, referrer and permissions policy headers are set
WEB-004	Unsafe API requests require same-origin JSON	PASS	.State-changing API requests are checked for Origin and JSON content type
WEB-005	Admin browser client sends JSON content type for mutations	PASS	.Browser requests include JSON content type for state-changing calls
OPS-001	Environment files and signing material ignored by Git	PASS	.Local secrets and Android signing files are ignored

نتایج تست‌های خودکار پنل وب و API

نتیجه تست‌های استخراج‌شده از TAP: 8 موفق و 0 ناموفق از 8 تست.

#	سناریوی تست وب/API	نتیجه
1	admin API: auth, read routes and management actions	PASS
2	demo credentials admin / 123456 work without environment overrides	PASS
3	demo server refuses production mode and non-loopback binding by default	PASS
4	demo HTTP responses have security headers and unsafe requests enforce same-origin JSON	PASS
5	admin UI hides inactive views and provides online/offline user filtering	PASS
6	admin web assets are versioned and cannot be served stale from browser cache	PASS
7	Admin Web uses the bundled Bonyade Koodak FaNum font without changing Android assets	PASS
8	Admin Web serves all bundled WOFF2 weights with the correct font MIME type	PASS

نتایج تست‌های اندروید و Code Quality

تعداد تست‌های JUnit جمع‌آوری‌شده: 0 | Fail/Error: 0 | Pass: 0.

در اجرای محلی فعلی، تست‌های Gradle اندروید اجرا نشده‌اند؛ بنابراین برای آن‌ها نتیجه Pass گزارش نمی‌شود. این مراحل در GitHub Actions تعریف شده‌اند و پس از اجرا، فایل‌های JUnit XML در همین گزارش تجمیع می‌شوند.

Android Lint

وضعیت Android Lint در این اجرا: NOT RUN یا ناموفق؛ تعداد یافته‌ها قابل اعلام نیست.

گزارش Android Lint در این اجرا تولید نشده است؛ بنابراین تعداد یافته‌ها مشخص نیست و صفر بودن عدد نباید به معنی بدون هشدار بودن کد تلقی شود. در اجرای CI، یافته‌های XML در همین بخش درج می‌شوند.

JaCoCo Code Coverage

خروجی JaCoCo در این اجرا در دسترس نیست؛ درصد پوشش کد اعلام نمی‌شود.

سابقه تست‌های Android از گزارش قبلی

جدول زیر از فایل ANDROID-QA-REPORT.md تجمیع شده است و مربوط به اجرای قبلی CI است، نه اجرای محلی فعلی. این تفکیک برای حفظ سابقه خطای Lint و جلوگیری از مخلوط‌شدن نتایج اجراهای مختلف انجام شده است.

بررسی سابقه اندروید	نتیجه قبلی	توضیح
AppRules Kotlin compile + smoke harness	PASS	assertions; local harness, not Android Gradle 10
AppRulesTest.kt source tests	PASS	test methods executed using a local Kotlin harness with stubs; not Gradle 14
Previous GitHub Actions: testDebugUnitTest	PASS	Recorded in ANDROID-QA-REPORT.md
Previous GitHub Actions: jacocoTestReport	PASS	Task completed; no coverage percentage is asserted here
Previous GitHub Actions: assembleDebug	PASS	Build completed; artifact was not published
Previous GitHub Actions: lintDebug	FAIL	errors and 13 warnings were recorded 2
Previous GitHub Actions: connectedDebugAndroidTest	NOT RUN	Workflow did not reach the Emulator stage
Previous Debug APK artifact publication	NOT PUBLISHED	Blocked by the failed Lint quality gate
Gradle/Lint revalidation after remediation	NOT RUN	No local Gradle/Android SDK available; new CI run is required

در اجرای قبلی، تست JVM، گزارش JaCoCo و ساخت Debug APK موفق بودند؛ اما lintDebug با ۲ خطا و ۱۳ هشدار شکست خورد. تست Emulator به اجرا نرسید و APK به‌عنوان Artifact منتشر نشد. پس از Patch بررسی مجوزهای CAMERA و RECORD_AUDIO، اجرای مجدد Gradle/Lint هنوز تأیید نشده است.

وضعیت فونت پنل مدیریت

فونت Bonyade Koodak FaNum در پنل وب بسته‌بندی شده است. این تغییر مختص Admin Web بوده و فایل‌های فونت و سورس اندروید در محدوده تغییر فونت و این اصلاح پایپ‌لاین دست‌نخورده باقی مانده‌اند.

بررسی	جزئیات	نتیجه
Admin Web font	Bonyade Koodak FaNum	PASS
Bundled weights	(WOFF2) 900 ,800 ,700 ,500 ,400 ,300 ,200 ,100	PASS
HTTP font delivery	HTTP 200 / font/woff2	PASS
Android source and font assets	No Android font changes in the font-update scope	PASS

تغییرات امنیتی و فنی اعمال‌شده

1. سرور دمو پنل ادمین به‌صورت پیش‌فرض فقط روی 127.0.0.1 اجرا می‌شود و اجرای آن در NODE_ENV=production مسدود است.
2. هدرهای امنیتی مرورگر، سیاست CSP، محافظت ضد فریم، کنترل Origin و JSON برای درخواست‌های تغییردهنده فعال شده‌اند.
3. مدیریت نشست دمو شامل HttpOnly، SameSite=Strict، انقضای نشست، Logout و محدودیت تلاش ورود است.
4. در اندروید، Cleartext غیرفعال، Trust Anchor محدود، Backup غیرفعال، FileProvider محدود و R8/Resource Shrinking برای Release فعال شده است.

5. فونت Admin Web با Bonyade Koodak FaNum و هشت وزن WOFF2 جایگزین شده؛ فایل‌های اندروید از این تغییر مستثنا هستند.

6. Workflow امنیت شامل Static Checks، تست‌های Web/API، ساخت وب، تست/Lint/Release اندروید، CodeQL، Gitleaks و OSV است.

یافته‌ها و موانع انتشار Production

شدت	یافته / ریسک	وضعیت
Critical	Production backend/API، هویت سمت سرور، RBAC/ABAC و Session Store واقعی وجود ندارد.	باز / مانع انتشار
High	اعتبارنامه دمو admin / 123456 ثابت است؛ فقط برای اجرای محلی Loopback قابل قبول است.	باز برای Production
High	داده محلی اندروید هنوز لایه رمزنگاری اختصاصی مبتنی بر Android Keystore ندارد.	باز
High	PWA، Service Worker و سیاست Cache هنوز در سورس وجود ندارند.	خارج از دامنه فعلی؛ لازم پیش از عرضه PWA
High	RBAC، MFA واقعی، Rotation توکن، KMS و Audit تغییرناپذیر بدون بک‌اند قابل ارزیابی نیستند.	مسدود توسط نبود بک‌اند
High	تست نفوذ مستقل و تست‌های Runtime بر اساس MASTG/WSTG اجرا نشده‌اند.	باز
Medium	کلید امضای Release و Play App Signing هنوز برای محیط انتشار تنظیم نشده‌اند.	باز

محدودیت‌های این گزارش

- نتیجه NOT RUN به معنای موفقیت نیست. مراحل CodeQL، Gitleaks، JaCoCo، Release، Lint، Android Gradle و OSV فقط پس از اجرای Workflow در GitHub نتیجه قطعی خواهند داشت.
- تست‌های فعلی API روی سرور JSON دمو و محیط محلی انجام شده‌اند؛ آن‌ها امنیت یک بک‌اند واقعی یا سرویس Production را تأیید نمی‌کنند.
- Instrumented UI tests on an Android Emulator are configured in the security workflow; their result remains NOT RUN until that workflow completes.
- اعتبارسنجی XML اندروید فقط درستی ساختار XML را می‌سنجد و جایگزین Android Lint، تست JVM یا Build APK نیست.
- این گزارش گواهی انطباق OWASP یا تأییدیه تست نفوذ مستقل محسوب نمی‌شود.

استانداردها و مراجع مرجع

- OWASP MASVS / MASTG
- OWASP ASVS
- OWASP API Security
- NIST SSDF
- Google Play Target API Requirements

این گزارش حاصل شواهد موجود در همین اجرای Pipeline است. وضعیت NOT RUN به معنی Pass نیست. اجرای کامل کنترل‌ها و تست نفوذ مستقل برای ارزیابی آمادگی Production لازم است.